

# Revisión Papers 2

Ricardo Conejeros Maldonado

## Software Bill of Materials Adoption- A Mining Study from GitHub

### ¿Cuál es el problema que se está resolviendo?

El artículo aborda la baja adopción de SBOM (Software Bill of Materials) en proyectos de código abierto. Siendo esta una herramienta que aumenta la seguridad y transparencia en dependencias de los proyectos, no existen herramientas ni prácticas que garanticen su uso.

### ¿Cuál es la nueva idea que están proponiendo?

El artículo propone una evaluación sistemática del ecosistema actual de SBOMs: herramientas, formatos, precisión y cobertura, con el objetivo de evidenciar que no solo con su existencia en proyectos se asegura que no se esté en riesgos.

Se plantea la necesidad de trabajar en estándares de validación y evaluación de la calidad de los SBOMs, promoviendo más rigurosidad con el fin de evaluar la madurez del ecosistema SBOM.

### Puntos positivos

1. El uso de una gran cantidad de paquetes y herramientas reales proporciona una gran credibilidad al estudio.
2. Al centrarse en estándares líderes como SPDX y CycloneDX, el estudio prioriza herramientas con altos respaldos, aumentando su relevancia práctica.
3. Identificar que eventos externos como la orden de Biden influyen en el aumento de la adopción de SBOM.
4. SBOM es un tema vigente hoy en día por su correlación con la seguridad del software.

### Puntos negativos

1. El artículo no menciona herramientas o frameworks que se puedan utilizar para mejorar los SBOMs.
2. El paper se limita a enfocarse solo en dos lenguajes de programación como son Python y JavaScript.
3. El artículo solo se enfoca en repositorios como GitHub, dejando a fuera otras plataformas masivas como GitLab, reduciendo la generalidad de los resultados.

## Trabajo futuro

1. Estudiar como los desarrolladores interactúan y utilizan SBOMs en la práctica.
2. Ampliar el alcance del estudio a proyectos en GitLab y repositorios privados, al igual como a nuevas herramientas.

## Calificación 1-5

La calificación otorgada es de 4, el artículo es relevante pero su alcance es limitado y sería ideal contar con propuestas aplicables por los desarrolladores en el corto plazo.

## Puntos de discusión

Como la plataforma GitHub puede integrar de una mejor manera los SBOMs con el fin de masificar su uso.

Que rol deben ejercer instituciones, gobiernos u otros en el avance de los SBOMs.

## On the Accuracy of GitHub's Dependency Graph

### ¿Cuál es el problema que se está resolviendo?

El artículo evalúa la precisión de Dependency Graph de GitHub, utilizando herramientas como Dependabot y generadores de SBOM, el problema central es la inexactitud en la información entregada por Dependency Graph lo cual compromete la seguridad y la gestión de licencias.

### ¿Cuál es la nueva idea que están proponiendo?

El artículo propone un análisis a tres niveles backward (precisión de dependencias declaradas), forward (precisión de dependencias) y manifest/lock (consistencia con los archivos de gestión de paquetes).

Se identifican errores como enlaces rotos, versiones incorrectas, dependencias incorrectas o irrelevantes, esto promueve una falsa sensación de seguridad o la toma de decisiones incorrectas a los desarrolladores.

### Puntos positivos

1. El estudio se basa en 1000 repositorios populares, otorgando credibilidad a los hallazgos.
2. La realización de un análisis tripartito backward, forward y manifest/lock.
3. El uso de datos de diversas fuentes como GitHub, libraries.io y archivos lock, fortalecen la metodología y reduce el sesgo al depender de un solo origen de datos.

### Puntos negativos

1. El uso de una cantidad limitada de lenguajes evita obtener una visión más completa.
2. Aunque se identificaron errores en GitHub, no se sugirieron soluciones específicas para mejorar Dependency Graph.

### Trabajo futuro

1. Se debería extender el estudio a otros lenguajes y gestores de paquetes usados actualmente como Maven, pip o Cargo, con el fin identificar si los errores detectados son extrapolables a otros lenguajes y gestores.
2. Elaborar un complemento que pudiese verificar automáticamente inconsistencias en las dependencias e informara a los desarrolladores.

## Calificación 1-5

La calificación otorgada es de 4, el estudio proporciona información valiosa pero su alcance es limitado y el no presentar soluciones prácticas para GitHub reduce su impacto.

### Puntos de discusión

Se debería reducir el uso de Dependency Graph de GitHub en desmedro del análisis de los archivos manifest/lock.

Que tan confiables pueden ser las herramientas automáticas de análisis para que los programadores basen sus decisiones en ellas.

## **Software Bills of Materials Are Required. Are We There Yet**

### **¿Cuál es el problema que se está resolviendo?**

El artículo evalúa la baja adopción de Software Bills of Material (SBOM) en la industria de desarrollo de software, siendo este un tema se suma importancia para la gestión de vulnerabilidades.

Actualmente existe un sin numero de beneficios y una orden ejecutiva que fomenta su utilización, pero aun así la industria se encuentra reacia a masificar su uso.

### **¿Cuál es la nueva idea que están proponiendo?**

El artículo propone una revisión sistemática de literatura gris (200 artículos, blog y documentos) con el fin de identificar y categorizar los principales beneficios y desafíos a la adopción de SBOMs.

Los beneficios incluyen gestión de dependencias, gestión de vulnerabilidades, gestión de riesgos, gestión de licencias, ventaja competitiva y los desafíos destacan la falta de herramientas adecuadas, la ausencia de interoperabilidad entre estándares, la incertidumbre sobre el valor real de los SBOMs, el alto consumo de tiempo en su generación y la exposición a riesgos de transparencia.

El objetivo final es incentivar el trabajo en conjunto de los diferentes actores y promover el uso de SBOM en la industria.

### **Puntos positivos**

1. La revisión de 200 artículos permite evidenciar la visión de expertos y usuarios del área. Brindando una base solidad para identificar beneficios y desafíos.
2. El asociar las necesidades de SBOM con casos reales como Log4Shell y requerimientos gubernamentales, resalta su relevancia para empresas y proveedores.
3. Categorizar en beneficios y desafíos ayuda a identificar los obstáculos y oportunidades fundamentales para adoptar SBOM.

### **Puntos negativos**

1. La utilización de solo literatura gris podría provocar un sesgo u omitir hallazgos académicos validados.
2. Se identifican desafíos, pero no se proponen acciones concretas para poder resolver.

## **Trabajo futuro**

1. Combinar la documentación analizada con estudios académicos validados con el fin de contrarrestar perspectivas prácticas y teorías.
2. Explorar la creación de herramientas automáticas de generación y validación de SBOMs, que permitan la comparación de información generada con estándares validados como SPDX, CycloneDX y SWID.

## **Calificación 1-5**

La calificación otorgada es de 4, El articulo propone un análisis detallado, pero no propone soluciones prácticas que faciliten la adopción de SBOM.

## **Puntos de discusión**

Se debería impulsar un estándar de SBOM por parte de gobiernos o actores de la industria.